

QUERY INSIGHT

要件定義書

社員能力の可視化・人事考課・案件マッチング支援システム

Version 1.0 | 2026 年 7 月 12 日

対象者 経営層・人事・管理職・営業・開発担当・運用担当

想定技術 React + Vite / Spring Boot / MySQL / Docker / AWS EC2 / GitHub Actions

CONFIDENTIAL / INTERNAL USE

黒 × 黄を基調としたモダンな社内システム

文書管理情報

項目	内容
文書名	Query Insight 要件定義書
文書番号	QI-RD-001
版数	1.0
作成日	2026 年 7 月 12 日
文書状態	初版・要件合意前
対象範囲	社内 Web システム（人事考課・案件マッチング支援）
取扱区分	社内利用想定 / 人事情報を含むため取扱注意
作成単位	Query Insight プロジェクト

改訂履歴

版数	日付	変更内容	承認
1.0	2026-07-12	初版作成	未承認

文書の読み方

本書では、現時点で明確な内容を「確定」、実務上必要と判断して追加した内容を「推奨」、関係者間の合意が必要な内容を「要確認」として区別する。要確認事項は、基本設計へ進む前に意思決定する。

区分	意味	取扱い
確定	利用目的、採用技術、主要機能など、依頼内容で明示された事項	要件として採用
推奨	目的達成・安全運用のため追加が妥当な事項	原則採用。不要なら理由を記録
要確認	数値、運用責任、評価ロジックなど、組織合意が必要な事項	未決事項一覧で管理

本書の位置付け

本書は「何を実現するか」を合意する要件定義書である。クラス構成、API 詳細、テーブル物理定義、AWS の具体的設定値などは、基本設計・詳細設計で確定する。

目次

01	文書の目的と前提	4
02	プロジェクト概要	5
03	現状課題と目標	7
04	対象範囲	8
05	ステークホルダーと権限	9
06	業務要件・業務フロー	10
07	機能要件	11
08	画面・ユーザビリティ要件	17
09	データ要件	19
10	評価・スコアリング要件	21
11	生成 AI 利用要件	24
12	セキュリティ・個人情報要件	26
13	非機能要件	28
14	システム構成・技術方針	30
15	データ移行要件	33
16	運用・保守要件	35
17	テスト・受入条件	36
18	導入・教育・定着	38
19	リスク・制約・前提	39
20	未決事項と合意チェック	40
付録 A	機能要件一覧	42
付録 B	用語集・参考資料	44

最重要メッセージ

Query Insight の価値はレーダーチャートや AI そのものではない。評価基準、根拠、承認、履歴、権限が整備されて初めて、意思決定に利用できる。

01 文書の目的と前提

要件定義の目的、想定読者、採用方針を明確にする。

1.1 文書の目的

本書は、社員のスキル・業務経歴・資格・評価情報を一元管理し、人事考課、案件マッチング、教育計画および組織分析を支援する「Query Insight」の業務要件・機能要件・非機能要件を定義する。関係者が完成像、対象範囲、責任分界および受入条件を共通認識として持つことを目的とする。

1.2 想定読者

対象者	本書で確認する内容
経営層	目的、期待効果、投資範囲、AI 利用方針
人事担当	評価制度、閲覧範囲、運用責任、個人情報
管理職・上長	評価基準、承認フロー、部下情報の利用範囲
営業担当	案件条件、検索・マッチング結果の利用方法
開発担当	機能境界、データ、セキュリティ、受入基準
運用担当	監視、バックアップ、障害対応、権限棚卸し

1.3 要件定義の基本方針

- 人事・給与・配置に関する最終判断は人間が行い、AI は説明・要約・候補提示に限定する。
- 社員同士を単純な総合点だけで順位付けせず、職種・役割・案件条件に応じた適合性を重視する。
- 自己評価、上長評価、確定評価、AI 分析を別データとして保持し、混同しない。
- 更新・閲覧・出力・AI 実行の履歴を記録し、後から判断経緯を確認できるようにする。
- 初期リリースは目的達成に必要な MVP へ絞り、案件管理高度化や組織分析は段階導入する。

判断基準

「便利か」だけでなく、評価の公平性、説明可能性、情報漏えいリスク、社員の入力負担、運用継続性を同時に評価する。

02 プロジェクト概要

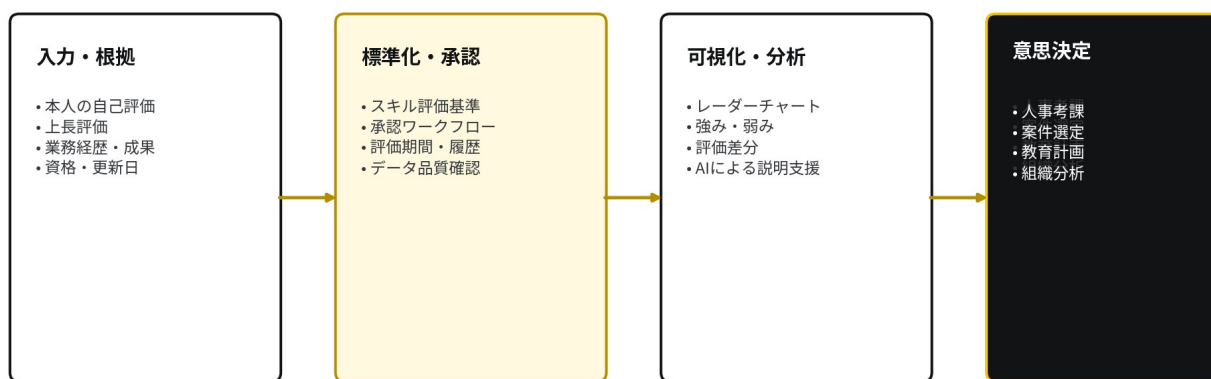
システムの目的、対象業務、期待効果を定義する。

2.1 システム名

Query Insight

2.2 システムの目的

会社の一般職以上の権限を持つ利用者が、社員ごとに可視化されたスキルマップ、業務経歴、資格、自己評価、上長評価およびAI分析結果を参照し、人事考課、案件マッチング、教育計画、配置検討などの意思決定に役立てる。一般社員は、自身の情報を更新し、強み・弱み・成長状況を確認する。



重要：AIやグラフではなく、「評価基準・根拠・承認・履歴」が信頼性を決める。

2.3 期待効果

観点	現状	目標状態	評価指標例
情報管理	複数 Excel とメールで分散	Web 上で一元管理し、最新版を共有	更新率、重複ファイル削減
人事評価	上長の肌感覚に依存	共通基準と根拠を用いた多角評価	根拠入力率、評価差の説明率
案件選定	目視確認で時間がかかる	条件検索と適合理由で候補を絞る	候補抽出時間、参画後ミスマッチ
社員育成	弱点が把握しづらい	不足スキルと学習候補を可視化	育成計画作成率、半年後の変化
監査性	誰が変更・閲覧したか不明	変更・閲覧・出力履歴を追跡	監査ログ取得率

02 プロジェクト概要 - 2.4 成功条件

☐	社員が定期的に情報を更新し、一定期間以上古い情報を明確に識別できる。
☐	スキルレベルが統一基準で定義され、評価者間で説明できる。
☐	上長・人事が評価根拠と履歴を確認できる。
☐	案件候補の抽出結果に、適合条件・不足条件・情報更新日が表示される。
☐	AI 分析が参照データと注意事項を表示し、人間の判断を置き換えない。

03 現状課題と目標

Excel 管理で発生している問題を、解決すべき業務課題へ変換する。

3.1 現状課題

ID	課題	影響	原因
P-01	スキルの尺度が曖昧	案件ミスマッチ、人事評価への不信	経験有無・年数だけで能力を表現
P-02	最新ファイルが判別しづらい	古い情報で判断	Excel の複製とメール共有
P-03	情報の検索・比較に時間がかかる	営業・管理職の工数増加	社員ごとのファイルを目視確認
P-04	評価が主観に偏る	公平性・再現性が低い	共通基準、根拠、承認が不足
P-05	成長推移が見えない	教育計画を立てにくい	評価を上書きし、期間履歴がない
P-06	入力負担が大きい	更新されない	重複入力、自由記述、差分更新不可
P-07	閲覧・変更の追跡が困難	人事情報の不正利用を検知できない	監査ログ・細かな権限制御がない

3.2 目標状態

- ・社員情報、業務経歴、スキル、資格、評価をデータベースで一元管理する。
- ・レベルごとの行動基準と業務経歴の実績を結び付ける。
- ・評価期間ごとに自己評価・上長評価・確定評価を保存する。
- ・職種・役割に合わせたレーダーチャートと評価モデルを利用する。
- ・案件条件に対して適合・不足・確認事項を理由付きで表示する。
- ・個人情報を匿名化した上で、AI が要約・差分・学習候補を提示する。
- ・閲覧、更新、出力、権限変更、AI 実行を監査ログへ記録する。

3.3 解決しないこと

本システムは、社員の人格・将来性・勤務態度を機械的に断定するものではない。また、AI または総合点のみで給与、昇格、降格、配置、採否を自動決定しない。勤怠、給与計算、契約管理を直接行うシステムでもない。

悪い例

「総合点が高い社員から案件へ割り当てる」「AI が弱点と書いたので昇給を見送る」といった使い方は禁止する。案件要件、本人希望、稼働状況、上長確認を含めて判断する。

04 対象範囲

初期リリース、将来拡張、対象外を明確にする。

4.1 MVP（初期リリース）

領域	対象機能	理由
認証・認可	ログイン、ログアウト、パスワード変更、ロール・組織範囲制御	人事情報を安全に扱う前提
社員管理	検索、詳細、新規登録、更新、無効化	情報管理の基盤
経歴・資格・スキル	登録、更新、履歴、承認状態	評価根拠の蓄積
評価	自己評価、上長評価、差し戻し、確定、履歴	意思決定に必要な
可視化	レーダーチャート、評価差、更新日、根拠表示	能力の理解を支援
AI 分析	強み・弱み候補、情報不足、学習提案、根拠表示	人間の分析を補助
監査・通知	主要操作ログ、評価期限・更新依頼通知	安全運用と定着

4.2 Phase 2 候補

- 案件情報管理とスコアリング
- 複数社員の比較・組織スキル分布
- 業務経歴書の Excel/PDF 出力
- 人事・勤怠・認証基盤との外部連携
- 資格証明書のファイル管理
- スキル追加申請・承認
- AI 分析品質のフィードバック学習

4.3 対象外

- 給与計算・賞与計算そのもの
- 勤怠打刻・休暇申請
- 顧客との契約・請求管理
- 社員の私生活・健康・思想等の評価
- AI による人事判断の自動確定
- マイナンバーの保管

4.4 スcope変更管理

追加要望は、目的への寄与、法務・セキュリティ影響、開発工数、運用負担、リリース影響を評価し、変更管理票で承認する。MVP の受入に不要な機能は原則として Phase 2 へ分離する。

05 ステークホルダーと権限

誰がどの情報を閲覧・編集できるかを定義する。

5.1 利用者ロール

ロール	主な責務	主な権限
一般社員	自分の情報を最新化し、自己評価を提出	自分のプロフィール・経歴・スキル・資格の閲覧更新
上長・評価者	部下を評価し、根拠・コメントを登録	担当社員の閲覧、評価、差し戻し、承認
営業・案件担当	案件候補を検索し、適合理由を確認	公開範囲内のスキル・経歴・稼働情報を参照
人事	評価制度・期間・確定・訂正を管理	全社または担当範囲の評価管理・出力
システム管理者	アカウント・マスタ・運用を管理	社員登録、権限、マスタ、監査ログの管理
監査担当	不適切な閲覧や変更を確認	監査ログの参照（業務データ変更不可）

5.2 権限マトリクス（基本案）

情報・操作	本人	上長	営業	人事	管理者
基本プロフィール	参照/一部更新	担当範囲参照	公開項目参照	参照/更新	参照/更新
業務経歴・スキル	更新	担当範囲参照/承認	参照	参照	管理
自己評価	更新/提出	参照	不可	参照	原則不可
上長評価	確定後参照	更新/提出	不可	参照/確定	原則不可
給与・査定情報	別システム	権限に応じる	不可	参照	不可
AI 分析	本人分参照	担当範囲実行/参照	案件用要約のみ	実行/参照	運用確認
監査ログ	不可	不可	不可	限定参照	参照

必須方針

ロールだけでなく「自部署」「直属部下」「個別付与」などのデータ範囲を組み合わせる。管理者であっても、業務上不要な評価・給与情報を自由に閲覧できる設計にしない。

5.3 権限管理要件

- 権限は最小権限を原則とし、付与理由・付与者・期間を記録する。
- 異動、昇格、休職、退職時に権限を自動または運用手順で見直す。
- 代理評価者は対象期間と対象社員を指定して付与する。
- 権限変更および機密情報の閲覧は監査ログへ記録する。
- 半年に1回以上、権限棚卸しを実施する。

06 業務要件・業務フロー

入力、評価、確定、活用までの業務手順を定義する。

6.1 社員情報更新フロー

手順	実施者	処理	完了条件
1	本人	経歴・スキル・資格を更新し、根拠を登録	必須項目と更新日が保存される
2	システム	入力チェック、重複・期限・未入力を提示	重大な不整合がない
3	本人	確認依頼を提出	提出後は本人による重要項目変更を制限
4	上長	根拠を確認し、承認または差し戻し	承認状態とコメントを保存
5	システム	ダッシュボードと案件検索へ反映	反映日時を記録

6.2 評価フロー

状態	更新者	許可される操作	次の状態
未開始	人事	評価期間開始	本人入力中
本人入力中	本人	下書き、提出	本人提出済み
本人提出済み	上長	確認、差し戻し、評価開始	差し戻し / 上長評価中
差し戻し	本人	修正、再提出	本人提出済み
上長評価中	上長	評価、根拠、コメント、提出	上長提出済み
上長提出済み	人事	確認、差し戻し、確定	上長評価中 / 確定
確定	人事	参照、正式な訂正申請	訂正処理中
訂正処理中	人事	理由付き訂正・再確定	確定

6.3 案件マッチングフロー（Phase 2）

- 営業担当が必須条件・希望条件・除外条件・参画時期を登録する。
- システムが承認済みスキル、類似経歴、更新日、稼働状況を用いて候補を抽出する。
- 結果には適合条件、不足条件、確認が必要な条件、根拠経歴を表示する。
- 営業・上長が本人希望、現場特性、契約条件などを確認して候補を決定する。
- 参画結果と不一致理由を保存し、評価ロジックの改善材料とする。

6.4 例外フロー

評価期限超過、上長不在、退職・休職、組織異動、重複アカウント、資格失効、AI API 停止、データ移行不備が発生した場合の代替手順を運用手順書で定義する。処理を止めるだけでなく、担当者・通知先・復旧条件を明確にする。

07 機能要件

機能 ID、優先度、概要、主要受入条件を定義する。

優先度

Must：MVP に必須 / Should：初期リリースで可能な限り対応 / Could：Phase 2 候補。

7.1 認証・アカウント

ID	優先	機能	要件概要	主要受入条件
AUTH-001	Must	ログイン	社員番号またはメールアドレスとパスワードで認証し、JWT を発行する。	有効な利用者のみログインでき、無効化・ロック中は拒否される。
AUTH-002	Must	ログアウト	現在のログイン状態を終了し、リフレッシュトークン等を無効化する。	ログアウト後に再利用したトークンで保護 API へアクセスできない。
AUTH-003	Must	パスワード変更	現在パスワードを確認し、新しいパスワードへ変更する。	ポリシー違反・現在値不一致時は変更されない。
AUTH-004	Must	ログイン失敗制御	連続失敗を検知し、一時ロックまたは追加確認を行う。	ブルートフォースを抑止し、解除方法が定義されている。
AUTH-005	Should	パスワード再設定	本人確認後、一時 URL 等で再設定できる。	URL に期限と一回性があり、実行履歴が残る。
AUTH-006	Must	認可	ロール・組織・担当関係に基づき、画面と API を制御する。	URL 直接入力や API 直接実行でも不正アクセスできない。

07 機能要件 - 7.2 社員・組織管理

ID	優先	機能	要件概要	主要受入条件
EMP-001	Must	社員検索	氏名、社員番号、部署、役職、スキル、在籍状態等で検索する。	権限範囲外の社員は結果に表示されない。
EMP-002	Must	社員詳細	基本情報、スキル、経歴、資格、評価概要を表示する。	項目ごとの閲覧権限が適用される。
EMP-003	Must	社員登録	管理者が社員と初期権限を登録する。	社員番号・メールの重複を防止する。
EMP-004	Must	社員更新	基本情報、所属、上長、在籍状態を更新する。	変更前後と実行者が履歴に残る。
EMP-005	Must	社員無効化	退職等の社員を論理削除・ログイン停止する。	経歴・評価履歴は保持され、通常検索から除外可能。
ORG-001	Must	組織管理	部署、役職、上長部下関係、適用期間を管理する。	異動前後の所属履歴を確認できる。

07 機能要件 - 7.3 業務経歴・スキル・資格

ID	優先	機能	要件概要	主要受入条件
CAR-001	Must	業務経歴登録	案件、期間、工程、役割、技術、成果を登録する。	期間矛盾や必須漏れを検知する。
CAR-002	Must	業務経歴更新・削除	本人が下書きを修正し、承認済みは履歴を残して訂正する。	承認済みデータが無断で上書きされない。
SKL-001	Must	スキル入力	マスタからスキルを選択し、自己レベル・経験期間・根拠を登録する。	表記揺れを抑制し、根拠経歴を紐付けられる。
SKL-002	Must	スキル承認	上長が確認し、承認・差し戻しを行う。	承認状態と理由が保存される。
SKL-003	Should	スキル追加申請	未登録スキルを管理者へ申請する。	重複候補が提示され、承認後にマスタ化される。
CRT-001	Must	資格登録	資格名、取得日、有効期限、認定番号等を登録する。	期限切れを識別できる。
CRT-002	Should	資格証明確認	証明書を登録し、人事等が確認済みにする。	ファイル閲覧権限とウイルス検査が適用される。

07 機能要件 - 7.4 評価・コメント

ID	優先	機能	要件概要	主要受入条件
EVL-001	Must	評価期間管理	人事が対象期間、対象者、評価者、期限を設定する。	同一期間の重複や対象漏れを検知できる。
EVL-002	Must	自己評価	本人が評価項目ごとにレベルと根拠を登録し提出する。	下書きと提出済みを区別する。
EVL-003	Must	上長評価	上長が自己評価を参照し、独立した評価と根拠を登録する。	自己評価を上書きしない。
EVL-004	Must	差し戻し・再提出	理由付きで差し戻し、本人または上長が修正する。	差し戻し履歴が残る。
EVL-005	Must	評価確定	人事または承認者が評価を確定する。	確定後は直接更新できない。
EVL-006	Must	評価履歴・比較	期間ごとの評価、差分、根拠を表示する。	評価基準バージョンを含めて比較できる。
CMT-001	Should	コメント	上長・人事が公開範囲を指定してコメントを登録する。	本人公開・人事限定等を区別する。

07 機能要件 - 7.5 可視化・AI・マッチング

ID	優先	機能	要件概要	主要受入条件
VIS-001	Must	個人ダッシュボード	総合概要、レーダーチャート、強み、弱み、更新状況を表示する。	表示値から根拠詳細へ遷移できる。
VIS-002	Must	評価比較	自己評価と上長評価、現在と過去を比較する。	対象期間と評価種別が明示される。
VIS-003	Should	組織ダッシュボード	部署のスキル分布や不足領域を集計する。	個人の不必要な露出を防止する。
AI-001	Must	能力分析	承認済みデータを基に、強み・弱み候補、情報不足、学習候補を生成する。	参照データ、実行日、注意事項を表示する。
AI-002	Must	分析履歴	入力要約、プロンプト版、モデル、出力、修正を保存する。	後から結果の再検証ができる。
AI-003	Must	匿名化・送信制御	外部 AI へ送る前に識別子・顧客機密を除去する。	送信項目を監査できる。
MAT-001	Could	案件登録	必須・希望・除外条件、時期、勤務条件を管理する。	条件の優先度を設定できる。
MAT-002	Could	候補抽出	案件条件と社員情報を比較する。	点数だけでなく適合・不足理由を表示する。

07 機能要件 - 7.6 通知・出力・監査・マスタ

ID	優先	機能	要件概要	主要受入条件
NTF-001	Must	システム内通知	評価依頼、差し戻し、期限、更新依頼を通知する。	既読状態と通知日時を管理する。
NTF-002	Should	メール等通知	重要通知をメールまたは Teams/Slack へ送る。	送信失敗を再確認できる。
EXP-001	Should	業務経歴書出力	権限に応じて Excel/PDF 等で出力する。	出力内容・実行者・日時が記録される。
AUD-001	Must	監査ログ	ログイン、閲覧、更新、削除、出力、権限変更、AI 実行を記録する。	検索でき、業務利用者が改ざんできない。
MST-001	Must	スキルマスタ	カテゴリ、スキル、表示順、適用期間を管理する。	削除で過去データが破損しない。
MST-002	Must	評価基準マスタ	職種・役職別の項目、レベル定義、重み、版を管理する。	期間に対して適用版を固定できる。

08 画面・ユーザビリティ要件

画面構成、入力負担、アクセシビリティ、デザインを定義する。

8.1 画面一覧

画面 ID	画面名	主な利用者	主要機能
SCR-001	ログイン	全利用者	認証、エラー表示、再設定導線
SCR-002	個人ダッシュボード	全利用者	レーダー、評価差、更新状況、AI 要約
SCR-003	社員検索	上長・営業・人事・管理者	条件検索、並び替え、権限フィルタ
SCR-004	社員詳細	権限保持者	プロフィール、経歴、スキル、資格、評価
SCR-005	社員登録・編集	管理者	基本情報、所属、権限、在籍状態
SCR-006	業務経歴編集	本人・管理者	案件経歴、工程、役割、成果、技術
SCR-007	スキル編集	本人	スキルレベル、経験、根拠、下書き
SCR-008	資格編集	本人	資格、取得日、有効期限、証明
SCR-009	自己評価	本人	評価、根拠、提出
SCR-010	上長評価	上長	評価、差分、コメント、差し戻し
SCR-011	評価管理	人事	期間、対象者、進捗、確定、訂正
SCR-012	AI 分析	本人・上長・人事	分析実行、根拠、履歴、フィードバック
SCR-013	通知	全利用者	通知一覧、既読
SCR-014	マスタ管理	管理者・人事	スキル、資格、評価基準、組織
SCR-015	監査ログ	管理者・監査	条件検索、詳細、出力

8.2 共通レイアウト

- ヘッダー：会社名、システム名、現在日時、ログイン社員名、通知、ログアウトを表示する。
- 左サイドバー：権限に応じてダッシュボード、社員検索、スキル、業務経歴、資格、評価、コメント、パスワード変更、管理メニューを表示する。
- パンくず・画面タイトル・操作ボタンの位置を全画面で統一する。
- 保存、提出、確定、削除を視覚的に区別し、確定・削除は確認ダイアログを表示する。

08 画面・ユーザビリティ要件 - 8.3 デザイン・入力・エラー

要素	要件
基本配色	黒・ダークグレーを基調とし、黄色をアクセントに使用する。
質感	ガラス調・ソリッド感のあるカードを利用するが、可読性を優先し過剰な透過を避ける。
文字	日本語が読みやすいサンセリフ体。本文のコントラストを確保する。
グラフ	色だけに依存せず、凡例・数値・ラベルを併記する。
状態表示	成功、警告、エラー、未確定を色とアイコン・文言で区別する。
レスポンス	PCを主対象とし、スマートフォンでは参照と簡易入力可能な設計を目指す。

8.4 入力負担の軽減

- 下書き保存と自動保存
- 前回評価・過去経歴のコピー
- マスタ選択と検索候補
- 入力進捗率と未入力項目表示
- 業務経歴から利用スキル候補を提示
- 必須項目の最小化と自由記述の文字数目安

8.5 エラー表示

「入力に誤りがあります」だけで終わらず、対象項目、原因、修正方法を表示する。サーバーエラー時は個人情報や技術スタックトレースを画面へ出さず、問い合わせ用エラー ID を表示する。

09 データ要件

管理対象、品質、履歴、保持、論理削除の方針を定義する。

9.1 主要データエンティティ

分類	主要データ	設計上の要点
社員・組織	社員、部署、役職、所属履歴、上長関係、ロール	適用開始・終了日を持ち、異動履歴を保持
経歴	案件経歴、工程、役割、使用技術、成果	顧客機密を入力しないルールを適用
スキル	カテゴリ、スキルマスタ、本人スキル、経験期間、根拠	マスタ ID で管理し、表記揺れを防止
資格	資格マスタ、取得資格、期限、証明状態	失効・更新・確認済みを区別
評価	評価期間、評価項目、自己評価、上長評価、確定評価、コメント	評価種別と基準版を別管理
AI	分析要求、匿名化入力、出力、モデル、プロンプト版、評価	再現性と監査性を確保
案件	案件条件、必須・希望条件、候補、判断結果	Phase 2。条件と結果時点を保存
運用	通知、監査ログ、ファイル、ジョブ実行履歴	業務データと分離して保護

9.2 データ品質要件

- 社員番号、メールアドレス、スキル名等の重複を防止する。
- 開始日が終了日より後になるなど、期間矛盾を検知する。
- スキルレベルには評価根拠または関連経歴を要求する。
- 最終更新日と承認状態を常に表示し、古い情報であることを隠さない。
- 一定期間未更新のデータを警告し、案件検索で「要確認」として扱う。
- 資格の有効期限切れを自動判定する。

9.3 履歴・論理削除

社員、組織、スキルマスタ、評価基準、承認済み経歴は原則として物理削除せず、無効化または有効期間で管理する。変更前後、変更理由、実行者、日時を履歴化する。個人情報の保持期間満了時は、人事・法務の承認に基づき削除または匿名化する。

09 データ要件 - 9.4 保持期間（要確認）

データ	暫定方針	確定主体
在籍社員データ	在籍中は保持	人事
退職者の経歴・評価	退職後5～7年を候補とし、社内規程・法務確認で確定	人事・法務
監査ログ	1～3年を候補。機密操作は長期化を検討	情報セキュリティ
AI分析履歴	必要最小限。評価期間＋監査要件で確定	人事・情報セキュリティ
資格証明ファイル	資格有効期間および確認目的に必要な期間	人事

注意

保持期間は本書だけで断定できない。会社規程、雇用管理、紛争対応、個人情報保護の観点から、人事・法務・情報セキュリティ部門が確定する。

10 評価・スコアリング要件

公平性、根拠、職種差、レーダーチャートの計算方針を定義する。

10.1 スキルレベル基準（共通案）

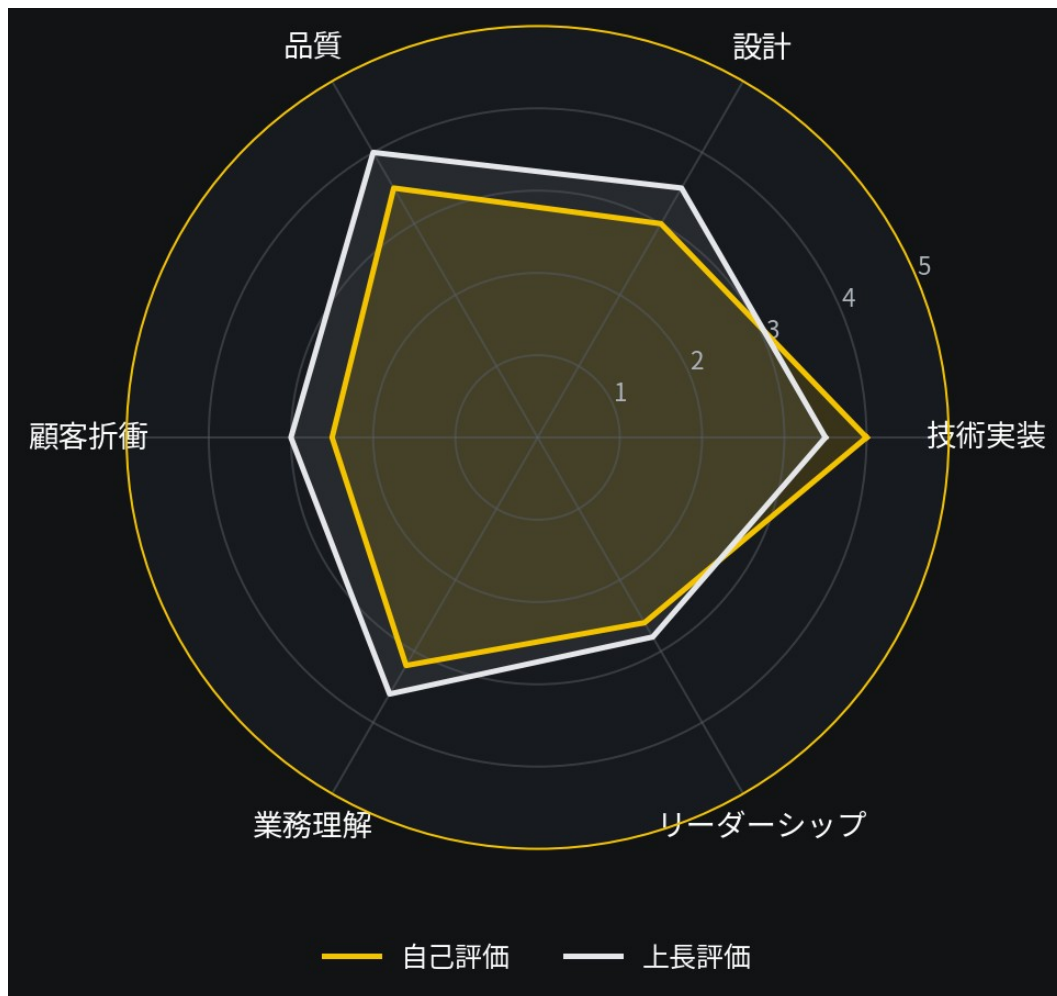
レベル	共通定義	必要な根拠例
0	未経験・未評価	登録なし、または評価対象外
1	学習経験があり、用語や基本概念を説明できる	学習履歴、演習
2	支援・レビューを受けながら定型作業を実施できる	担当タスク、成果物
3	通常業務を単独で遂行し、問題を調査・解決できる	案件経歴、上長確認
4	設計・レビュー・改善・指導ができる	設計責任、レビュー、育成実績
5	組織または複数案件で方針・技術選定を主導できる	標準化、意思決定、成果

共通定義だけでは不十分なため、Java、設計、顧客折衝、マネジメントなどの各評価項目に具体的な行動例を設定する。
経験年数だけでレベルを自動決定しない。

10.2 評価種別

種別	入力者	用途	注意
自己評価	本人	自己認識、面談材料	確定評価と混同しない
上長評価	上長	業務成果・行動の評価	評価根拠を必須化
確定評価	人事/承認者	正式な評価期間結果	確定後は訂正手続き
AI 分析	システム	説明・不足情報・学習候補	点数の確定や人事判断に使用しない

10 評価・スコアリング要件 - 10.3 可視化・算出・バイアス対策



六角形のレーダーチャートは、初期案として「技術実装・設計・品質・顧客折衝・業務理解・リーダーシップ」の6軸を想定する。ただし、若手エンジニア、営業、管理職を同一軸で評価すると不公平になるため、職種・役割別テンプレートを用意する。

10.4 スコア算出ルール

- 軸スコアは、その軸に紐付く評価項目の加重平均とする。
- 重み、評価項目、丸め方法、欠損値の扱いを評価基準版として保存する。
- 未評価項目を0点として扱わず、「データ不足」として表示する。
- 自己評価と上長評価を単純平均して確定評価にしない。面談・承認を経て確定する。
- 総合評価A～Eを設ける場合、職種別の基準と境界値を明示し、相対評価か絶対評価かを定める。
- 評価制度変更後も、過去の評価は当時の基準版で再現できるようにする。

10.5 暫定計算例

例

設計軸 = 基本設計×40% + 詳細設計×30% + 影響調査×15% + レビュー×15%。これは説明用の例であり、実際の重みは人事・現場責任者が合意する。

10 評価・スコアリング要件 - 10.6 評価バイアス対策

- 評価者向け基準説明と具体例
- 評価者ごとの平均・分布差の確認
- 自己評価との差が大きい項目の面談
- 属性情報を不要に AI へ渡さない
- 評価根拠が少ない項目の警告
- 人事によるキャリブレーション会議

11 生成 AI 利用要件

AI の役割、禁止事項、匿名化、根拠、品質管理を定義する。

11.1 AI 利用目的

- 登録情報の要約
- 強み・弱みの候補提示
- 自己評価と上長評価の差分説明
- 不足情報・矛盾の指摘
- 案件適合理由の文章化
- 次に学ぶ内容の候補提示

11.2 AI に禁止する判断

禁止対象	理由
給与・賞与額の決定	経済的に重大な判断を自動化しない
昇格・降格・解雇の確定	人間の説明責任と多角判断が必要
人格・性格・忠誠心の断定	入力データから正当に判断できない
健康、思想、家庭状況等の推測	目的外利用・プライバシー侵害の危険
AI 出力だけによる案件除外	情報不足や誤推論による機会損失を防ぐ

11.3 AI 分析処理要件

ID	要件
AI-R01	承認済みデータを基本入力とし、未確認情報は区別して表示する。
AI-R02	氏名、社員番号、メールアドレス、顧客名、具体的案件名などを原則として匿名化・一般化する。
AI-R03	入力項目、匿名化結果、プロンプト版、モデル識別子、実行日時、出力を記録する。
AI-R04	出力には参照した根拠データと「AI による参考情報」である旨を表示する。
AI-R05	不適切・誤り・根拠不足を利用者が報告し、修正または非表示にできる。
AI-R06	AI API 停止時でも、登録・評価・参照などの主要業務は継続できる。
AI-R07	API 利用料金、回数、失敗率、応答時間を監視し、上限を設定する。
AI-R08	外部 AI 事業者のデータ利用・保存条件を契約・設定で確認する。

11 生成 AI 利用要件 - 11.4 出力表示・ガバナンス

☐	分析対象期間
☐	参照したデータ種別と更新日
☐	情報不足・未承認データの有無
☐	AI 分析の実行日時
☐	AI モデルまたはサービス識別情報
☐	人事判断を自動決定しない旨
☐	利用者の修正・フィードバック導線

11.5 ガバナンス方針

AI 利用は、総務省・経済産業省「AI 事業者ガイドライン（第 1.2 版）」の人間中心、公平性、プライバシー保護、セキュリティ、透明性、アカウンタビリティ等の考え方を参照する [R1]。本番導入前に、利用目的、リスク、責任者、停止基準を記載した AI 利用台帳を作成する。

実務ポイント

AI 機能は最後に追加する。先に評価基準・履歴・権限・匿名化を整備しなければ、AI は曖昧なデータを説得力のある文章へ変換してしまう。

12 セキュリティ・個人情報要件

人事情報を守るための認証、認可、ログ、暗号化、個人情報管理を定義する。

12.1 情報分類

分類	例	取扱い
公開不可・機微	評価コメント、確定評価、AI 分析、権限情報	厳格な閲覧制御、出力制限、監査
社内限定	社員基本情報、スキル、業務経歴、資格	業務上必要な範囲で参照
機密	認証情報、トークン、秘密鍵、API キー	画面・ログへ出力せず、専用保管
禁止入力	マイナンバー、不要な健康情報、顧客秘密の詳細	システムへ登録しない

12.2 認証・JWT 要件

- バックエンド API は Spring Security で保護し、Bearer JWT を検証する。Spring Security は JWT を含む Bearer Token 保護をサポートする [R5]。
- アクセストークンは短時間有効とし、リフレッシュ方式・ローテーション・失効管理を設ける。具体値はセキュリティ設計で確定する。
- トークンへ評価内容・個人情報など不要な情報を含めない。
- ログアウト、パスワード変更、アカウント無効化時に再認証・失効を適切に行う。
- 管理者・人事への多要素認証は Should 要件として導入可否を確認する。

12.3 パスワード

パスワードは平文または復号可能な形式で保存せず、Spring Security が提供する適応型一方向関数を利用する。bcrypt 等は実行環境で検証時間を測定して強度を調整する [R6]。初期パスワードの固定配布を避け、初回変更または一時再設定 URL を使用する。

12 セキュリティ・個人情報要件 - 12.4 アプリケーションセキュリティ

領域	要件
入力検証	DTO で型・桁・必須・許容値を検証し、サーバー側検証を必須とする。
認可	すべての保護 API で対象データへのアクセス権を検証する。
SQL	JPA 等のパラメータ化を利用し、文字列連結による動的 SQL を避ける。
XSS	React の標準エスケープを維持し、任意 HTML 挿入を原則禁止する。
CORS	許可オリジン、メソッド、ヘッダーを本番環境で限定する。
ファイル	拡張子・MIME・サイズ・マルウェア・保存場所を検査する。
エラー	内部例外、SQL、トークン、個人情報を画面や外部レスポンスへ出さない。
依存関係	GitHub 等で脆弱性を検出し、重大度に応じた更新期限を設定する。

セキュリティ受入基準には OWASP ASVS 5.0.0 および OWASP Top 10:2025 を参照し [R2] [R3]、日本語の実装確認には IPA「安全なウェブサイトの作り方」も併用する [R4]。

12 セキュリティ・個人情報要件 - 12.5 個人情報・監査

- 利用目的、利用者、閲覧範囲、AI 利用、保存期間を社員へ明示する。
- 個人データの取扱責任者、規程、教育、物理・技術的安全管理措置を整備する。個人情報保護委員会のガイドライン・Q&Aを確認する [R7]。
- 評価情報の閲覧、出力、AI 送信を監査ログへ記録する。
- 漏えい・不正アクセス時の連絡、封じ込め、調査、報告、再発防止手順を定義する。
- 外部 AI やクラウド事業者へデータを委託する場合、契約条件・保存先・再委託・削除を確認する。

13 非機能要件

性能、可用性、運用性、保守性、拡張性の暫定目標を定義する。

前提

社員数・同時利用数が未提示のため、以下は初期想定値である。基本設計開始前に実利用規模と予算を確認し、数値を確定する。

13.1 性能・容量（暫定）

ID	項目	暫定目標	測定条件
NFR-P01	通常画面表示	95%が3秒以内	社内ネットワーク、AI 処理除外
NFR-P02	社員検索	95%が2秒以内	社員 1,000 件、複合条件
NFR-P03	保存・更新	95%が2秒以内	ファイル・AI 除外
NFR-P04	AI 分析	通常 60 秒以内を目標	外部 API 状況に依存し非同期表示可
NFR-P05	同時利用	100 セッションを初期上限候補	ピーク評価期間を想定
NFR-P06	データ容量	社員 1,000 人、評価 10 年を想定	ファイル容量は別見積り

13.2 可用性・復旧（暫定）

項目	暫定要件
サービス時間	平日 7:00～23:00 を基本候補。評価期間は拡張を検討。
計画停止	事前通知し、原則として業務時間外に実施。
月間稼働率	初期 99.5%を候補。単一 EC2 構成では限界を明示する。
RTO	重大障害から 8 時間以内を暫定目標。
RPO	24 時間以内を暫定目標。DB バックアップ方式により短縮を検討。
バックアップ	日次自動取得、世代管理、定期的な復元試験。

13.3 運用・監視

- アプリケーション死活、HTTP エラー率、CPU、メモリ、ディスク、DB 接続、証明書期限を監視する。
- 重大エラー、ディスク逼迫、バックアップ失敗、デプロイ失敗を担当者へ通知する。
- 個人情報やトークンをログへ出力せず、相関 ID で追跡する。
- ログローテーションと保存期間を設定し、ディスク枯渇を防ぐ。
- AI 利用量と費用を監視し、月次上限を設定する。

13 非機能要件 - 13.4 保守性・品質・データ整合性

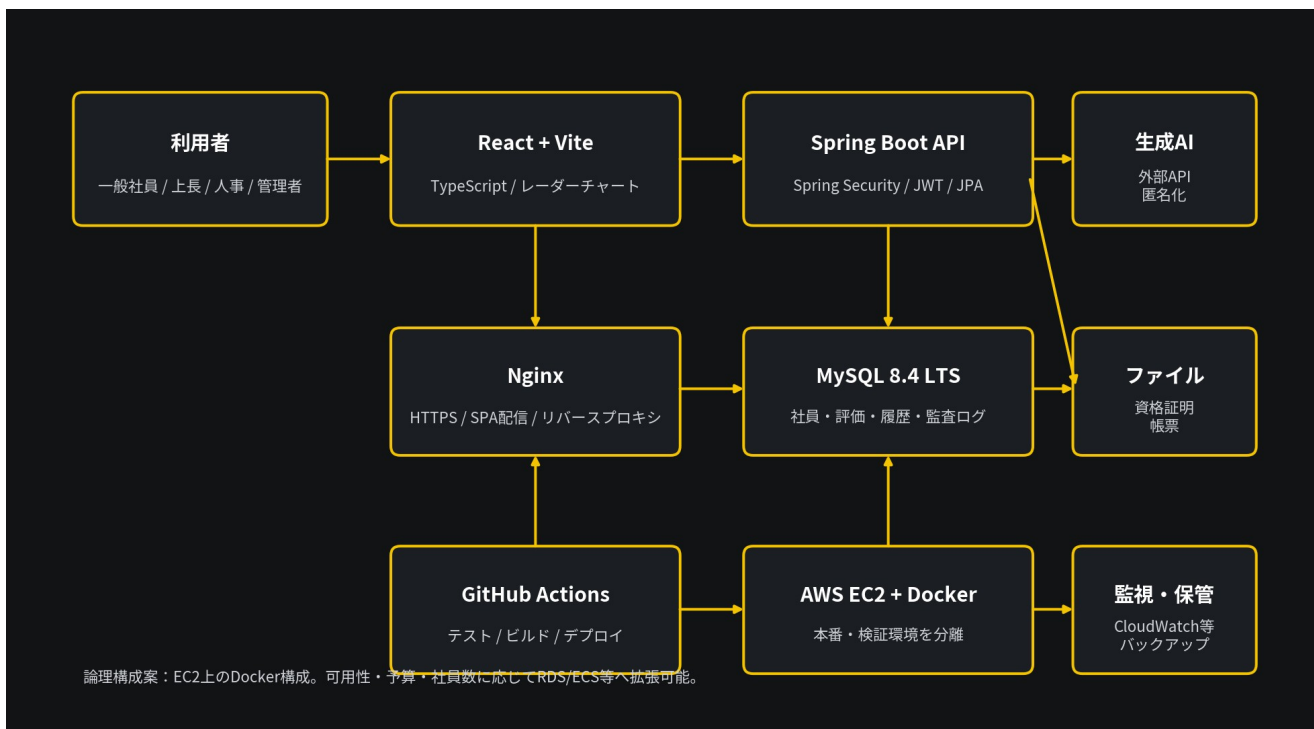
観点	要件
構成管理	GitHub でソース、設定テンプレート、マイグレーション、手順書を管理する。
テスト	バックエンド単体・結合、フロント単体、E2E、セキュリティをCIで実行する。
DB 変更	Flyway 等のマイグレーションで版管理し、手動変更を原則禁止する。
API	OpenAPI 等で仕様を管理し、フロント・バック間の認識差を減らす。
監査可能性	リリースしたコミット、イメージ、DB 版を追跡できる。
ドキュメント	運用、障害、バックアップ、権限、AI 利用手順を整備する。

13.5 非機能要件の確定方法

IPA「非機能要求グレード 2018」を観点整理に用い、可用性、性能・拡張性、運用・保守性、移行性、セキュリティ、システム環境・エコロジーの各項目を利用部門と開発部門で合意する [R8]。

14 システム構成・技術方針

採用技術、構成案、CI/CD、環境分離を定義する。



14.1 採用技術

レイヤー	採用候補	方針
フロントエンド	React + TypeScript + Vite	VS Code で開発。SPA として Nginx 等から配信。
バックエンド	Java + Spring Boot + Spring Security + Spring Data JPA	Eclipse で開発。REST API を提供。
データベース	MySQL 8.4 LTS 系	MySQL 8.0 は 2026 年 4 月に EOL となったため、新規構築では 8.4 LTS を候補とする [R9] 。
SQL クライアント	DBeaver	開発・調査用途。接続情報と本番権限を制限。
実行基盤	AWS EC2 + Docker / Docker Compose	初期コストを抑える構成。将来は RDS/ECS 等を検討。
CI/CD	GitHub Actions	テスト、イメージ作成、配備、ヘルスチェック、ロールバック。
バージョン管理	GitHub	Pull Request レビューとブランチ保護を適用。

14 システム構成・技術方針 - 14.2 環境分離・Docker

- ローカル開発環境
- 検証環境
- 本番環境

本番と検証は、少なくとも設定・DB・秘密情報・公開 URL を分離する。同一 EC2 上へ同居させる場合でも、ポート、ネットワーク、ボリューム、認証情報を分け、本番データを検証へコピーしない。

14.3 EC2 上の Docker 方針

- Nginx、Spring Boot、必要に応じて MySQL をコンテナ化する。DB を同一 EC2 に置く場合は、障害・バックアップ・容量のリスクを明示する。
- アプリケーションイメージはマルチステージビルド等で不要なツールを含めず、脆弱性スキャンを行う。
- コンテナは非 root 実行、読み取り専用化、最小権限、ヘルスチェック、再起動方針を設定する。
- 永続データをコンテナ層へ保存せず、ボリュームまたは管理サービスへ保存する。
- EC2 への GUI 操作のみを正式手順にせず、再現可能な設定・スクリプト・手順書を Git で管理する。

14 システム構成・技術方針 - 14.4 CI/CD・デプロイ

AWS 認証には、長期的なアクセスキーを GitHub Secrets へ保存する方式より、GitHub Actions の OpenID Connect を利用した短期認証を優先する。GitHub 公式ドキュメントは、OIDC により長期 AWS 資格情報を保存せずアクセスできるとしている [R10]。

段階	処理	失敗時
1	静的解析・依存脆弱性確認	デプロイ停止
2	フロント・バックエンドの単体/結合テスト	デプロイ停止
3	Docker イメージ作成・スキャン	重大脆弱性で停止
4	検証環境へデプロイ・ヘルスチェック	自動または手動でロールバック
5	承認後に本番デプロイ	旧イメージへ戻せるよう保持
6	DB マイグレーション・疎通確認	後方互換性と復旧手順を確認

15 データ移行要件

既存 Excel から安全に移行し、二重管理を終了するための要件を定義する。

15.1 移行対象

- 社員基本情報
- 所属・役職・上長
- 業務経歴
- スキル・経験年数
- 保有資格
- 過去評価（存在する場合）

15.2 移行手順

工程	内容	成果物
調査	Excel 種類、所有者、最新版、項目、件数、機密情報を把握	移行元一覧
標準化	表記揺れ、日付、部署、スキル、資格名を統一	変換ルール
クレンジング	重複、欠損、矛盾、古い情報を分類	エラー一覧
試行移行	検証環境へ投入し、件数・項目・関係を照合	試行結果
利用者確認	本人・上長が内容を確認	承認記録
本番移行	凍結期間を設け、差分を投入	本番移行結果
切替	Excel の更新を停止し、参照専用または保管	切替完了報告

15.3 移行品質基準

☐	移行元件数と移行先件数が説明可能
☐	社員番号等の一意性が保たれている
☐	文字化け・日付ずれ・改行崩れがない
☐	スキル・資格の表記揺れがマスタへ統合されている
☐	移行不能データが一覧化され、責任者が判断している
☐	本番切替後の Excel 更新停止ルールが周知されている

15 データ移行要件 - 15.4 注意点

古い Excel の内容をすべて正しい前提で移行しない。「移行済み」は「確認済み」を意味しないため、本人確認・上長確認の状態を別に管理する。顧客名・プロジェクト詳細に営業秘密や個人情報が含まれる場合は、移行前に削除・一般化する。

16 運用・保守要件

運用責任、定常作業、障害対応、バックアップ、変更管理を定義する。

16.1 運用体制

役割	責務
業務責任者	利用目的、評価制度、データ利用範囲の決定
人事運用者	評価期間、対象者、確定、訂正、問い合わせ
システム管理者	アカウント、権限、マスタ、ジョブ、監査ログ
インフラ担当	EC2、Docker、証明書、監視、バックアップ、障害復旧
開発担当	不具合修正、機能改善、依存更新、リリース
AI 管理責任者	AI 利用目的、プロンプト、品質、費用、停止判断
監査・セキュリティ担当	権限棚卸し、不正閲覧、インシデント確認

16.2 定常運用

頻度	作業
日次	バックアップ成否、死活、エラー、ディスク、AI API 失敗を確認
週次	未処理通知、ジョブ失敗、脆弱性警告を確認
月次	利用状況、AI 費用、性能、障害傾向、未更新社員を確認
半期	権限棚卸し、評価基準・マスタ見直し、復元試験
随時	入退社・異動、資格更新、脆弱性対応、証明書更新

16.3 障害対応

- 検知：監視または利用者報告でインシデント番号を発行する。
- 初動：影響範囲、個人情報漏えい可能性、サービス継続可否を判断する。
- 封じ込め：必要に応じて機能停止、認証情報失効、ネットワーク遮断を行う。
- 復旧：バックアップ、旧イメージ、DB マイグレーション手順で復旧する。
- 報告：原因、影響、対応、再発防止、ログ保全を記録する。

16.4 リリース・変更管理

すべての変更は Issue または変更票と Pull Request に関連付け、レビュー・テスト・承認後に配備する。評価基準、AI プロンプト、権限ロジック、DB 変更は業務影響が大きいため、通常機能より厳格な承認を行う。緊急修正後も事後レビューを必須とする。

17 テスト・受入条件

品質を確認するテスト範囲と、利用部門の受入基準を定義する。

17.1 テストレベル

テスト	主な対象	重点観点
単体テスト	サービス、計算、バリデーション、React 部品	境界値、例外、権限分岐
API 結合テスト	Controller〜DB、認証認可	HTTP 状態、トランザクション、データ範囲
画面結合テスト	入力、検索、グラフ、エラー	操作性、更新競合、表示権限
E2E	ログイン〜評価確定	主要業務フローと差し戻し
性能テスト	検索、一覧、同時評価	ピーク負荷と DB 索引
セキュリティテスト	認証、認可、入力、依存、設定	権限漏れ、脆弱性、秘密情報
バックアップ復元	DB、ファイル、構成	RTO/RPO、復元後整合性
AI 品質評価	要約、根拠、禁止判断、匿名化	誤り、偏り、機密送信、再現性
受入テスト	人事・上長・一般社員の業務	業務要件と運用可能性

17.2 必須テストシナリオ

☐	一般社員が他社員の評価 API へ直接アクセスしても拒否される。
☐	上長異動前後で、閲覧・評価対象が正しく切り替わる。
☐	自己評価、上長評価、確定評価が別データとして保存される。
☐	確定評価を通常操作で上書きできず、訂正理由が履歴に残る。
☐	レーダーチャートの各値が計算仕様と一致し、データ不足を 0 点にしない。
☐	AI 送信データから氏名、社員番号、顧客名が除去される。
☐	ログアウト・無効化後のトークン再利用が拒否される。
☐	Excel 移行後の件数・日付・日本語・関連が一致する。
☐	DB バックアップから検証環境へ復元できる。

17 テスト・受入条件 - 17.3 受入条件

分類	受入条件
機能	Must 要件が合意したシナリオで正常に動作し、重大欠陥がない。
権限	権限マトリクスに対する正・負のテストが完了している。
評価	人事が基準・計算・履歴・訂正フローを承認している。
AI	匿名化、根拠表示、禁止用途、停止時の代替が確認されている。
性能	合意したデータ量・同時利用で暫定目標を満たす。
運用	監視、バックアップ、復旧、問い合わせ、権限変更の手順がある。
移行	移行結果を本人・上長・管理者が確認できる。
教育	対象利用者向けの操作説明と評価基準説明が完了している。

18 導入・教育・定着

社員が継続利用するための展開方法と定着指標を定義する。

18.1 段階導入

段階	対象	目的
1. 試行	少人数の1部署	入力項目、評価基準、操作負担を検証
2. パイロット	複数職種・複数上長	権限、評価差、組織運用を検証
3. 全社展開	全対象社員	正式運用。Excel 更新を停止
4. 拡張	案件・組織分析	実績データを基に Phase 2 を判断

18.2 教育内容

- 一般社員：入力方法、根拠の書き方、AI 結果の見方
- 上長：評価基準、バイアス、差し戻し、コメント、説明責任
- 人事：評価期間、確定、訂正、権限、監査
- 管理者：アカウント、マスタ、障害、バックアップ
- 全員：個人情報、顧客機密、禁止入力、問い合わせ先

18.3 定着指標

指標	目標例	改善判断
プロフィール更新率	評価開始前に 90%以上	入力項目・通知・期限を見直す
上長承認期限内完了率	95%以上	評価者負荷・代理者を見直す
根拠付きスキル率	80%以上	入力補助・基準例を改善
月間利用率	対象ロール別に測定	利用価値・画面導線を改善
AI 結果の妥当評価	妥当/一部妥当の割合を追跡	プロンプト・入力品質を改善
案件抽出時間	従来 Excel より短縮	検索条件・更新率を改善

18.4 定着を妨げる要因

入力項目が多い、評価が監視のように感じられる、点数の使われ方が不透明、上長ごとに基準が違う、Excel との二重管理が残る、といった状態では利用されない。利用目的、閲覧範囲、本人のメリット、評価への反映方法を事前に説明する。

19 リスク・制約・前提

開発・運用上の主要リスクと対応方針を整理する。

19.1 リスク一覧

ID	リスク	影響	対応
R-01	評価基準が曖昧	数値が信用されない	職種別の行動基準と根拠例を策定
R-02	自己申告が過大・過小	案件・査定判断を誤る	上長確認、証拠、評価差表示
R-03	情報が更新されない	古い情報で判断	更新期限、通知、案件終了時更新
R-04	AI が誤った分析を生成	不公平な判断	根拠表示、人間確認、禁止用途
R-05	外部 AI へ機密情報送信	漏えい・契約違反	匿名化、送信項目制御、契約確認
R-06	権限設定ミス	評価情報の不正閲覧	データ範囲認可、テスト、棚卸し
R-07	単一 EC2 障害	サービス停止・データ損失	バックアップ、復旧試験、将来冗長化
R-08	Excel 移行の誤り	不正確な初期データ	試行移行、本人確認、エラー一覧
R-09	入力負担が大きい	利用率低下	下書き、コピー、選択式、段階導入
R-10	評価点が序列化される	社員の不信・萎縮	用途明示、職種別評価、説明・異議申立て

19.2 技術的制約

- AWS EC2 上の Docker を初期デプロイ先とする。
- フロントは React + Vite、バックエンドは Spring Boot、DB は MySQL を基本とする。
- GitHub Actions でテスト・デプロイを自動化する。
- GUI 操作を利用する場合でも、復旧可能な設定記録を残す。
- 外部 AI サービスの可用性・料金・規約に依存する。

19.3 前提条件

- 人事・管理職が評価基準策定に参加する。
- 社員へ利用目的と情報の扱いを説明する。
- 既存 Excel の所有者と最新版を特定できる。
- 本番運用担当と問い合わせ窓口を確保する。
- AI 利用について会社のセキュリティ・法務確認を受ける。

20 未決事項と合意チェック

基本設計開始前に決定すべき事項を明確にする。

20.1 最優先の未決事項

No.	決定事項	選択肢・論点	決定者	期限
1	「一般職以上」の具体的範囲	役職名、代理者、営業の範囲	経営・人事	基本設計前
2	評価項目・レベル基準	職種別 6 軸、具体的行動例	人事・現場	画面設計前
3	確定評価の決定方法	上長単独、人事承認、会議承認	人事	評価実装前
4	本人へ見せる情報	上長コメント、AI 分析、評価差	人事・法務	権限設計前
5	AI サービスと送信範囲	匿名化、保存、学習利用、リージョン	セキュリティ・法務	AI 実装前
6	社員数・同時利用数	性能、EC2 サイズ、DB 構成	業務・開発	インフラ設計前
7	MySQL 配置	同一 EC2、別 EC2、RDS	開発・運用	構築前
8	退職者・監査ログ保持期間	社内規程・法務・費用	人事・法務	DB 設計前
9	Excel 移行対象と責任者	何年分、誰が確認するか	人事・各部門	移行設計前
10	通知手段	システム内、メール、Teams/Slack	業務責任者	画面設計前

20 未決事項と合意チェック - 20.2 要件合意チェックリスト

☐	目的と対象外が経営・人事・開発で合意されている。
☐	ロールと閲覧範囲が項目単位で合意されている。
☐	評価基準、評価期間、確定者、訂正方法が決まっている。
☐	レーダーチャートの軸、計算、欠損値、基準版が決まっている。
☐	AI の利用目的、禁止判断、匿名化、契約確認が完了している。
☐	個人情報の利用目的、保存期間、退職時処理が確認されている。
☐	性能、可用性、RTO/RPO、運用時間が数値で合意されている。
☐	EC2・MySQL・バックアップ・監視の責任者が決まっている。
☐	移行元 Excel、変換ルール、本人確認方法が決まっている。
☐	MVP と Phase 2 が分離され、受入条件が明確である。

基本設計へ進む条件

上記 10 項目のうち、権限・評価・AI・個人情報・非機能の重要事項が未決のままでは、画面・API・DB 設計を確定しない。

21 付録 A：機能要件一覧

MVP の優先順位とリリース単位を俯瞰する。

ID	優先	リリース	機能
AUTH-001	Must	MVP	ログイン
AUTH-002	Must	MVP	ログアウト
AUTH-003	Must	MVP	パスワード変更
AUTH-004	Must	MVP	ログイン失敗制御
AUTH-005	Should	MVP	パスワード再設定
AUTH-006	Must	MVP	認可
EMP-001	Must	MVP	社員検索
EMP-002	Must	MVP	社員詳細
EMP-003	Must	MVP	社員登録
EMP-004	Must	MVP	社員更新
EMP-005	Must	MVP	社員無効化
ORG-001	Must	MVP	組織管理
CAR-001	Must	MVP	業務経歴登録
CAR-002	Must	MVP	業務経歴更新・削除
SKL-001	Must	MVP	スキル入力
SKL-002	Must	MVP	スキル承認
SKL-003	Should	MVP	スキル追加申請
CRT-001	Must	MVP	資格登録
CRT-002	Should	MVP	資格証明確認
EVL-001	Must	MVP	評価期間管理
EVL-002	Must	MVP	自己評価
EVL-003	Must	MVP	上長評価
EVL-004	Must	MVP	差し戻し・再提出
EVL-005	Must	MVP	評価確定
EVL-006	Must	MVP	評価履歴・比較
CMT-001	Should	MVP	コメント
VIS-001	Must	MVP	個人ダッシュボード
VIS-002	Must	MVP	評価比較
VIS-003	Should	MVP	組織ダッシュボード
AI-001	Must	MVP	能力分析

21 付録 A：機能要件一覧 - 後半・実装順・リリース判定

ID	優先	リリース	機能
AI-002	Must	MVP	分析履歴
AI-003	Must	MVP	匿名化・送信制御
MAT-001	Could	Phase 2	案件登録
MAT-002	Could	Phase 2	候補抽出
NTF-001	Must	MVP	システム内通知
NTF-002	Should	MVP	メール等通知
EXP-001	Should	MVP	業務経歴書出力
AUD-001	Must	MVP	監査ログ
MST-001	Must	MVP	スキルマスタ
MST-002	Must	MVP	評価基準マスタ

推奨実装順

順序	実装領域	理由
1	組織・社員・権限	すべてのデータ範囲の基盤
2	経歴・スキル・資格・マスタ	評価根拠を先に蓄積
3	評価ワークフロー・履歴・監査	意思決定に必要な信頼性を確保
4	ダッシュボード・レーダーチャート	確定した計算値を可視化
5	AI 分析	匿名化・根拠・履歴が整った後に追加
6	案件マッチング・組織分析	運用実績とデータ品質を確認して拡張

22 付録 B：用語集・参考資料

用語の統一と、要件作成時に参照した一次情報を示す。

用語集

用語	定義
JWT	JSON Web Token。認証後の API アクセスで使用する署名付きトークン。
アクセストークン	保護 API へアクセスする短期トークン。
リフレッシュトークン	アクセストークンを再発行するための長期側トークン。失効・ローテーションが必要。
RBAC	ロールを基に権限を付与する方式。本書では組織・担当範囲も組み合わせる。
レーダーチャート	複数評価軸を放射状に表示するグラフ。六角形は 6 軸の場合の形状。
確定評価	承認プロセスを完了した正式な期間評価。
評価基準版	評価項目、レベル定義、重み、計算方法を一組として管理するバージョン。
論理削除	データを物理削除せず、無効状態として通常処理から除外する方式。
RTO	障害発生後、サービスを復旧するまでの目標時間。
RPO	障害時に許容するデータ損失時点の目標。
OIDC	OpenID Connect。GitHub Actions から AWS へ長期キーなしで認証する用途にも使用可能。

参考資料

番号	資料	URL
[R1]	総務省・経済産業省「AI 事業者ガイドライン 第 1.2 版」2026 年 3 月 31 日	https://www.meti.go.jp/shingikai/mono_info_service/ai_shakai_jisso/20260331_report.html
[R2]	OWASP Application Security Verification Standard 5.0.0	https://owasp.org/www-project-application-security-verification-standard/
[R3]	OWASP Top 10:2025	https://owasp.org/www-project-top-ten/
[R4]	IPA「安全なウェブサイトの作り方」	https://www.ipa.go.jp/security/vuln/websecurity/about.html
[R5]	Spring Security Reference: OAuth 2.0 Resource Server / JWT	https://docs.spring.io/spring-security/reference/servlet/oauth2/resource-server/index.html
[R6]	Spring Security Reference: Password Storage	https://docs.spring.io/spring-security/reference/features/authentication/password-storage.html

22 付録 B：用語集・参考資料 - 参考資料（後半）・最終要約

番号	資料	URL
[R7]	個人情報保護委員会「個人情報保護法ガイドライン・Q&A」	https://www.ppc.go.jp/personalinfo/faq/APPI_QA/
[R8]	IPA「非機能要求グレード 2018」	https://www.ipa.go.jp/archive/digital/iot-en-ci/jyouryuu/hikinou/index.html
[R9]	MySQL 8.0 Release Notes / MySQL 8.4 LTS	https://dev.mysql.com/doc/relnotes/mysql/8.0/en/
[R10]	GitHub Docs: Configuring OpenID Connect in Amazon Web Services	https://docs.github.com/actions/security-for-github-actions/security-hardening-your-deployments/configuring-openid-connect-in-amazon-web-services

ファクトチェック時点

技術仕様・ガイドラインは2026年7月12日時点で確認した。開発着手時および本番リリース前に、各公式ドキュメントの最新版、サポート期限、ライセンス、利用規約を再確認する。特に Spring Boot/Security、React/Vite、Docker、MySQL、GitHub Actions、外部 AI API はバージョンを固定し、サポート期間と脆弱性対応方針を決定する。

最終要約

Query Insight の成立条件

評価基準と根拠、自己・上長・確定評価の分離、期間履歴、最小権限、監査ログ、AI の匿名化と説明可能性を先に整備する。これらを満たしたうえで、レーダーチャートと案件マッチングを意思決定支援として利用する。